

Navigating Security in Generative AI Development

Katherine Druckman
Open Source Security Evangelist

Why are we here?

Today we'll cover



Introduction to the GenAI Security Landscape



Security Challenges in Generative AI



Community Initiatives and Working Groups



Open Platform for Enterprise AI



Other AI + Security Communities



Future Direction and How to Get Involved

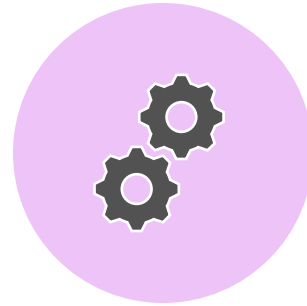
The Dream



GDP Growth

‘Generative AI could **raise global GDP by 7%**...over a 10-year period.’

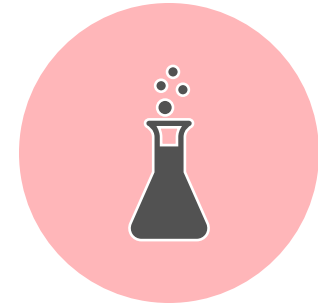
– Goldman Sachs,
April 2023



Productivity Gains

‘Generative AI’s impact on productivity could add **trillions of dollars** in value to the global economy.’

– McKinsey Report
June 2023

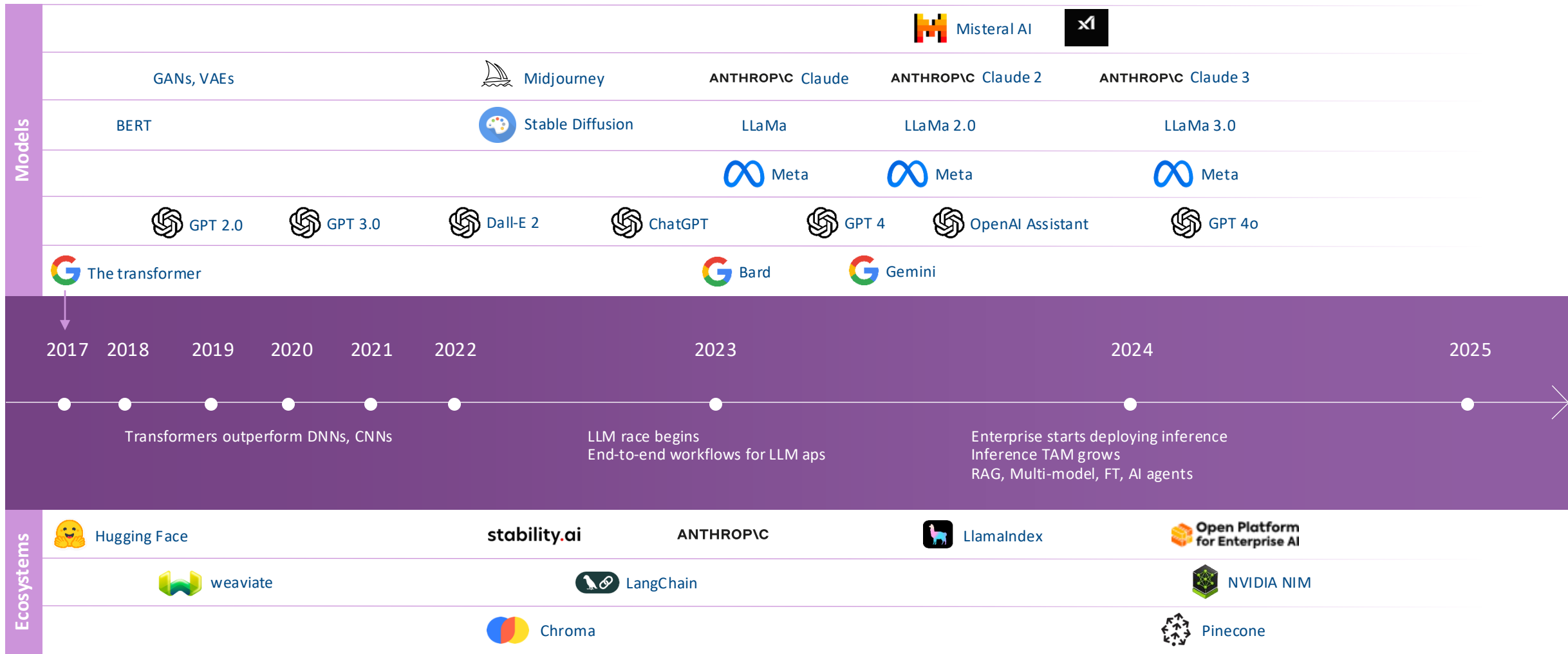


Innovation Acceleration

‘Drug development (scratch to pre-clinical) **from 4.5 years to 18 months.**’

– InSilico use cases, IDC
September 2023

GenAI: transformers to AI Agents in 8 years



Rapid Adoption

- Transition from experimental to business-critical deployments
- Cross-industry adoption:
 - Customer service
 - Content creation
 - Code generation
 - Decision support
- Dramatic increase in enterprise deployments

GenAI is moving rapidly, and we must
address security challenges rapidly.

Traditional AppSec

- Traditional focus on code vulnerabilities vs. model behavior
- Expanded attack surfaces in GenAI applications
- Novel attack vectors requiring specialized knowledge



Unique Challenges

 ChatGPT ▾

Log in

Sign up

What can I help with?

Tell me about some unique generative AI security concerns.

+ Attach

 Search

 Reason



 Summarize text

 Make a plan

 Brainstorm

 Code

 Surprise me

More

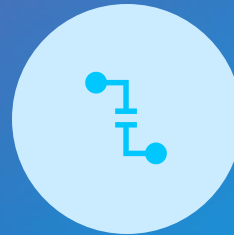
Some Categories of Risk



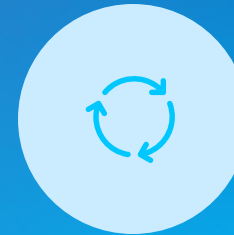
MODEL MANIPULATION:
ALTERING BEHAVIOR
THROUGH INPUTS



DATA EXTRACTION:
RETRIEVING SENSITIVE DATA
FROM RESPONSES



OUTPUT EXPLOITATION:
LEVERAGING GENERATED
CONTENT FOR ATTACKS



RESOURCE CONSUMPTION:
EXHAUSTING SYSTEM
RESOURCES



SUPPLY CHAIN RISKS:
COMPROMISED MODELS OR
TRAINING DATA

It's Getting Real

FBI issues warning about 'deepfakes' being used to secure jobs

by JILLIAN SMITH | The National Desk | Thu, July 28th 2022 at 5:03 PM

Updated Thu, July 28th 2022 at 5:35 PM

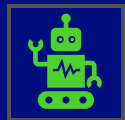


The Federal Bureau of Investigation is now issuing a warning about the dark side of deep fake videos, telling job recruiters to watch out for fake applicants as people are reportedly using those false videos to apply for remote work. (Photo courtesy of FBI – Federal Bureau of Investigation's Facebook)

Protecting Machine Learning Pipelines



AI systems are vulnerable to attacks during development



Organizations often outsource AI training or use pre-built models



Security breaches can lead to manipulated AI behavior



Small changes to training data can cause major problems

Two Major Threats



Data Poisoning

Attackers modify training data to create backdoors

Changes are often subtle and hard to detect

Can make AI misbehave in specific situations



Supply Chain Risks

Pre-trained models may contain hidden vulnerabilities

Training procedures might be compromised

Difficult to verify what happened during outsourced training

Three-Layer Security



1. Data Integrity

Track and verify all data sources
Digitally sign every piece of data and code



2. Real-Time Verification

Continuously monitor operations as they happen
Verify inputs before they're used
Generate proof of proper processing



3. Model Lineage

Create a complete "family tree" of model development
Record every step from data collection to deployment

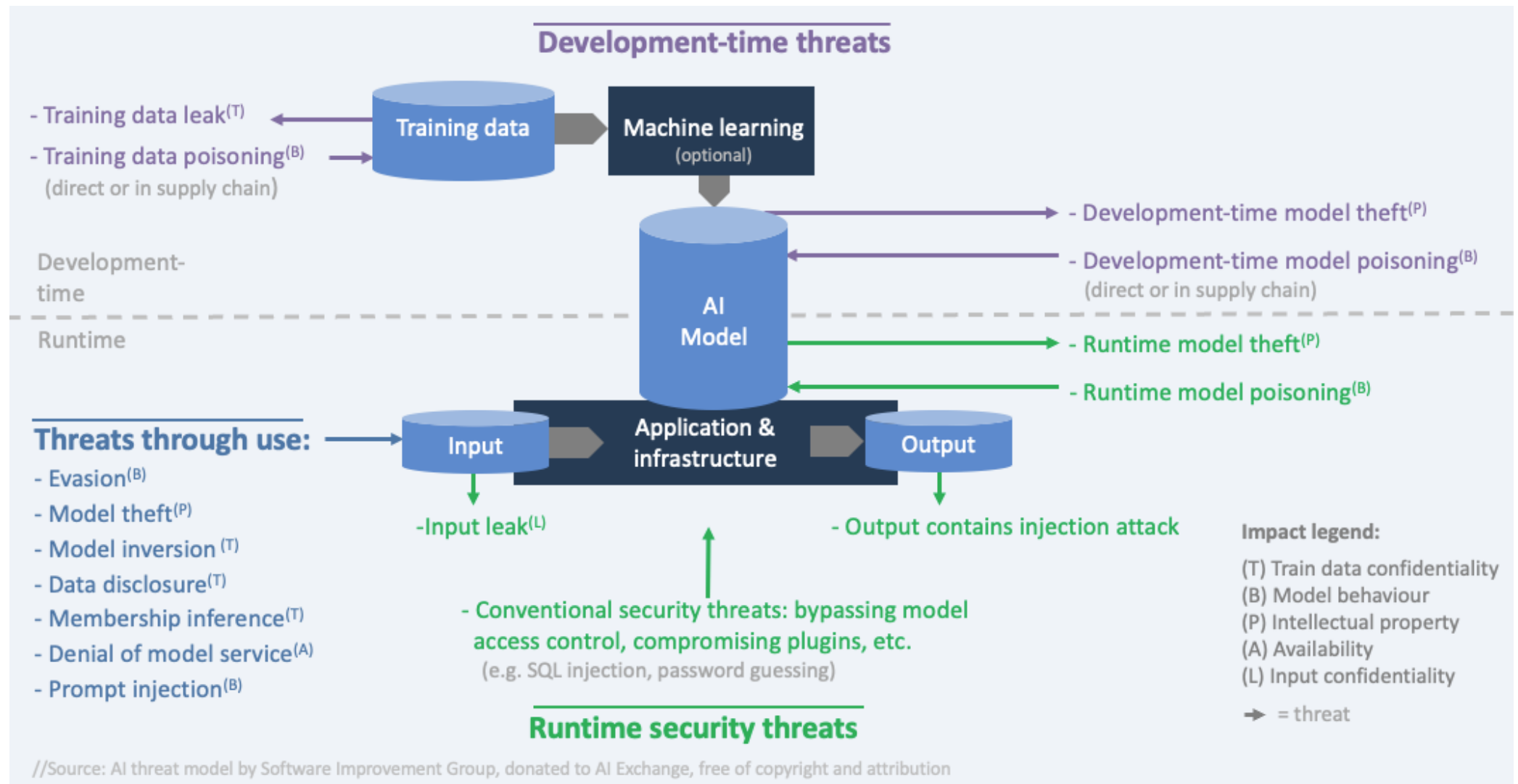
Security Initiatives

1. OWASP AI Exchange
2. OWASP LLM Top 10
3. MITRE ATLAS Framework
4. NIST AI Risk Management Framework
5. OPEA Security Working Group
6. OpenSSF AI/ML Working Group

OWASP AI Exchange

- Comprehensive open source resource for AI security
- Collaborative community-driven knowledge base
- Maps threats, controls, and best practices
- Provides a structured approach to AI security

Threat Model



Security Matrix

AI-specific?	Lifecycle	Attack surface	Threat/Risk category	Asset	Impacted	Unwanted result
AI	Operation	Model use (provide input/ read output)	Direct prompt injection	Model behaviour	Integrity	Manipulated unwanted model behaviour causes wrong decisions leading to business financial loss, misbehaviour going undetected, reputational damage, legal and compliance issues, operational disruption, customer dissatisfaction and churn, reduced employee morale, incorrect strategic decisions, liability issues, personal damage and safety issues
			Indirect prompt injection			
			Evasion (e.g. adversarial examples)			
		Break into deployed model	Model poisoning in runtime (reprogramming)			
	Development	Engineering environment	Model poisoning development time			
			Data poisoning of train/finetune data			
		Supply chain	Model poisoning in supply chain (transfer learning attack)			
	Operation	Model use	Data disclosure in model output	Training data	Confidentiality	Leaking sensitive data can cause costs from fines and legal fees and remediation effort, loss of business through customer churn, reputation damage, loss of competitive advantage in case of trade secrets, operational disruption, impacted business relationships, and employee morale issues
			Model inversion / Membership inference			
			Training data leak			
Generic	Operation	Model use	Model theft through use (input-output harvesting)	Model intellectual property	Confidentiality	If attackers can copy a model, the investment in the model is devalued caused by loss of competitive advantage, plus a copy can help craft (evasion) attacks
		Break into deployed model	Runtime model theft (not through use)			
		Engineering environment	Model theft development-time			
	Operation	Model use	Denial of model service (model resource depletion)	Model behaviour	Availability	The model is not available, leading to business continuity issues, or safety problems
	Operation	All IT	Model input leak	Model input data	Confidentiality	Sensitive data in model input leaks. E.g. an LLM prompt with a sensitive question, enhanced with retrieved company secrets
	Operation	All IT	Model output contains injection attack	Any asset	C, I, A	Injection attack (from model output) causes harm
	Operation	All IT	Generic runtime security attack	Any asset	C, I, A	Generic runtime security attack causes harm (includes social engineering/phishing)
	Development	All IT	Generic supply chain attack	Any asset	C, I, A	Generic supply chain security attack causes harm (e.g. vulnerability in a component)

Mitigations

Input validation for prompts

Input segregation

Limit unwanted behavior through guardrails

Detection of odd or adversarial inputs

Runtime model integrity protections

Appropriate model access controls

2025 Top 10 for Large Language Models

1. Prompt injection
2. Sensitive information disclosure
3. Supply chain vulnerabilities
4. Data/model poisoning
5. Improper output handling
6. Excessive agency
7. System Prompt Leakage
8. Vector and Embedding Weaknesses
9. Misinformation
10. Unbounded consumption

MITRE Atlas Framework

- Adversarial Threat Landscape for Artificial-Intelligence Systems
- MITRE ATT&CK-inspired approach to AI security
- Comprehensive catalog of attack techniques
- Knowledge base of real-world incidents

ATLAS Matrix

The ATLAS Matrix below shows the progression of tactics used in attacks as columns from left to right, with ML techniques belonging to each tactic below. & indicates an adaption from ATT&CK. Click on the blue links to learn more about each item, or search and view ATLAS tactics and techniques using the links at the top navigation bar. View the ATLAS matrix highlighted alongside ATT&CK Enterprise techniques on the [ATLAS Navigator](#).

Reconnaissance&	Resource Development&	Initial Access&	ML Model Access	Execution&	Persistence&	Privilege Escalation&	Defense Evasion&	Credential Access&	Discovery&	Collection&	ML Attack Staging	Exfiltration&	Impact&
5 techniques	9 techniques	6 techniques	4 techniques	3 techniques	4 techniques	3 techniques	3 techniques	1 technique	6 techniques	3 techniques	4 techniques	4 techniques	7 techniques
Search for Victim's Publicly Available Research Materials Search for Publicly Available Adversarial Vulnerability Analysis Search Victim-Owned Websites Search Application Repositories Active Scanning&	Acquire Public ML Artifacts Obtain Capabilities& Develop Capabilities& Acquire Infrastructure Publish Poisoned Datasets Poison Training Data Establish Accounts& Publish Poisoned Models Publish Hallucinated Entities	ML Supply Chain Compromise Valid Accounts& Evade ML Model Exploit Public-Facing Application& LLM Prompt Injection Phishing&	AI Model Inference API Access ML-Enabled Product or Service Physical Environment Access Full ML Model Access	User Execution& Command and Scripting Interpreter& LLM Plugin Compromise	Poison Training Data Backdoor ML Model LLM Prompt Injection LLM Prompt Self-Replication	LLM Prompt Injection LLM Plugin Compromise LLM Jailbreak	Evade ML Model LLM Prompt Injection LLM Jailbreak	Unsecured Credentials&	Discover ML Model Ontology Discover ML Model Family Discover ML Artifacts LLM Meta Prompt Extraction Discover LLM Hallucinations Discover AI Model Outputs	ML Artifact Collection Data from Information Repositories& Data from Local System&	Create Proxy ML Model Backdoor ML Model Verify Attack Craft Adversarial Data	Exfiltration via ML Inference API Exfiltration via Cyber Means LLM Meta Prompt Extraction LLM Data Leakage	Evade ML Model Denial of ML Service Spamming ML System with Chaff Data Erode ML Model Integrity Cost Harvesting External Harms Erode Dataset Integrity

NIST AI Risk Management Framework



Released by the National Institute of Standards and Technology (NIST)

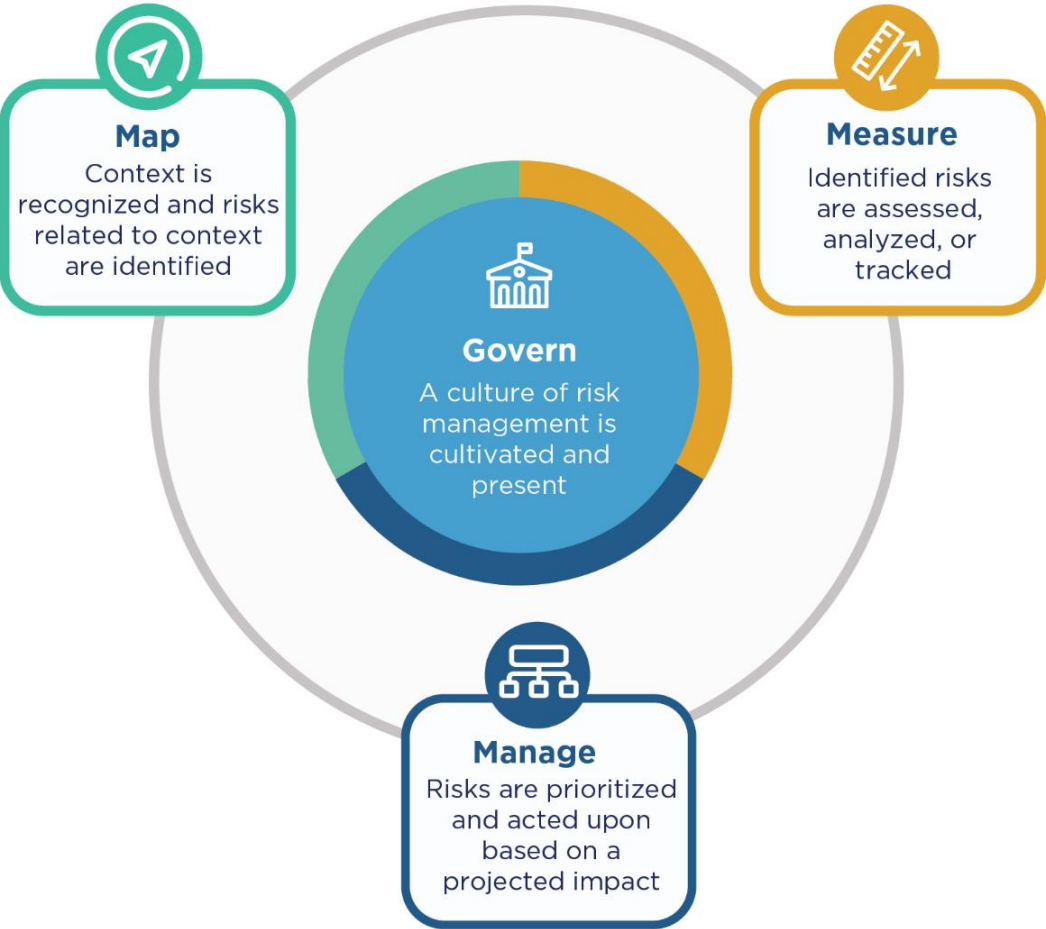


A voluntary framework to better manage risks to individuals, organizations, and society



Designed to be adaptable to all AI systems and use cases

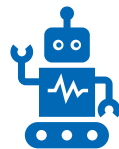
Four Core Elements



Implementation & Benefits



Integrates with existing organizational risk management processes



Addresses both technical and socio-technical dimensions of AI



Scales according to organization size, sector, and risk profile



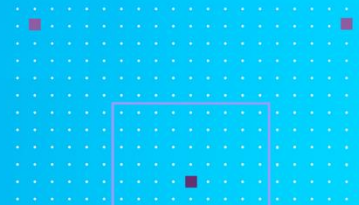
Promotes trustworthy AI that is valid, reliable, safe, secure, and fair



Supports continuous improvement throughout the AI lifecycle

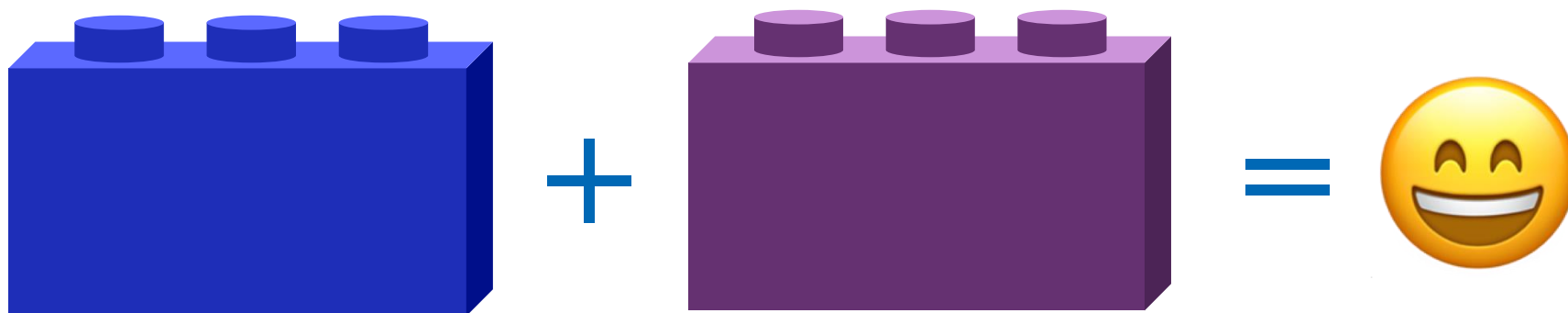
A Newer Project

Open Platform for Enterprise AI (OPEA)



Why standardization matters

Life is easier when things go together



Massive innovation, expensive duplication, no standardization

- So many options, how do decide?
- Constantly reinventing the wheel
- Few best practices, wasted dev cycles.
- Multiple, circuitous routes to the same place
- Can we be pioneers without so much chaos?



We've created a monster!

Without standards Gen AI RAG can be a beast!



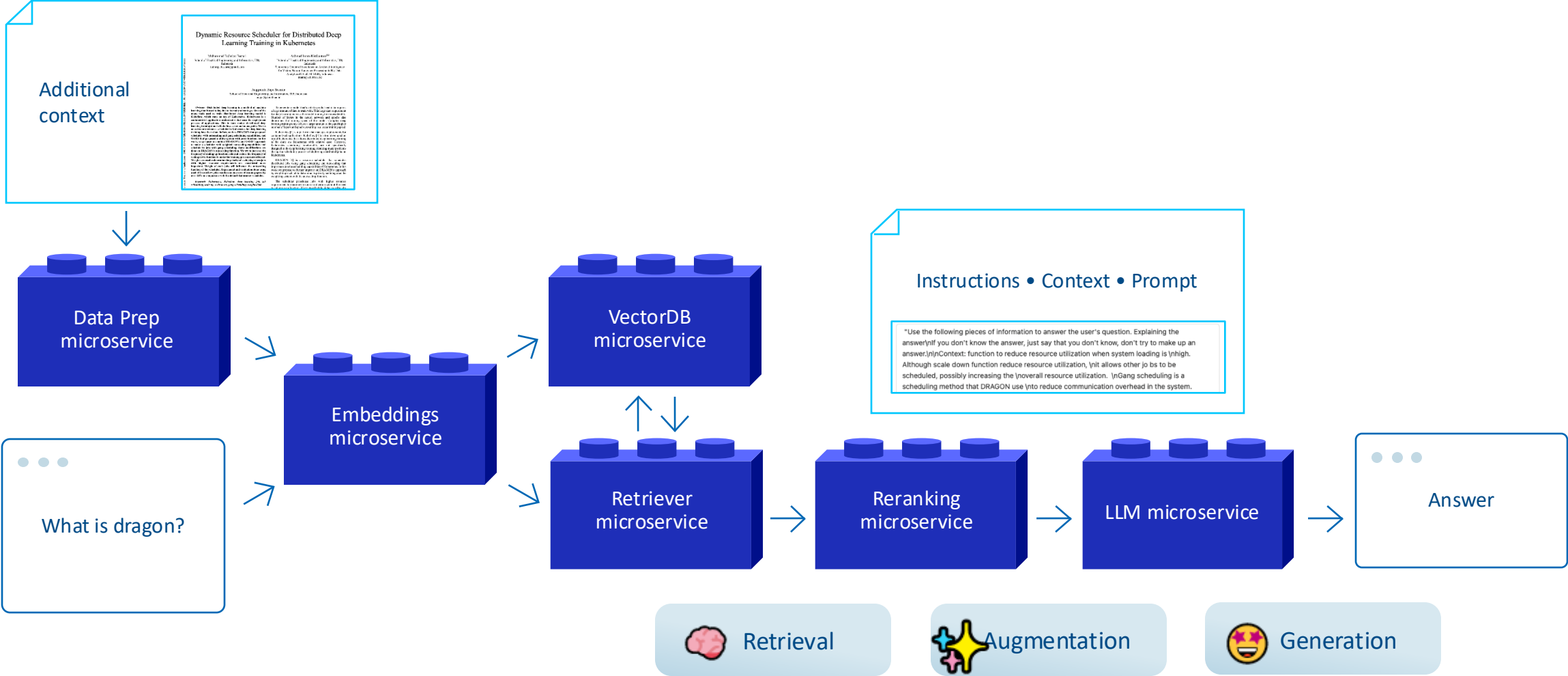
Open source platform that organizes GEN AI chaos



**Open Platform
for Enterprise AI**

- Composable building blocks for generative AI systems
- Integrates LLMs, data stores, and prompt engines
- RAG AI blueprint with component stack structure and end-to-end workflow
- Additional stacks for translation, code generation, images
- Generative AI assessment tool for performance, features, trustworthiness and enterprise-grade readiness

How OPEA ChatQnA answers on context



RAG conclusions and challenges

The good

- RAG is a great approach to having context-based answers
- OPEA makes the building blocks easy to deploy

The challenges

- Dealing with a large amount of data (Play with different similar search techniques)
- Different types of data (Images/Tables) – Intel Tech on Medium articles
- Is it all about indexing? Explore Retrieval augmented text-to-SQL generation

Get involved in OPEA

Join the Security Working Group!



Open Platform for Enterprise AI

OPEA.dev

OPEA Security Working Group

<https://github.com/o pea-project/Security-Working-Group>

Mission

- The OPEA Security Working Group aims to establish a "Security First" mindset in the community in order to prevent and respond to security issues.

Problem Statement

- It's often the case that security is only prioritized after a problem – at which point it's the hardest most expensive time to address. Moreover without a structured response process in place security issues are even more difficult to remediate.

Scope and Priority

- The Security Working Group will adopt best practices from established security organizations and educate the community to ensure widespread adoption, i.e., security is everyone's responsibility. Working Group members will also act as subject matter experts to help review pull requests for secure design and implementation.

OpenSSF AI/ML Working Group

Be your own hero!

openssf.org

The best way to influence an OSS project direction is to get involved.



Intel's Contributions

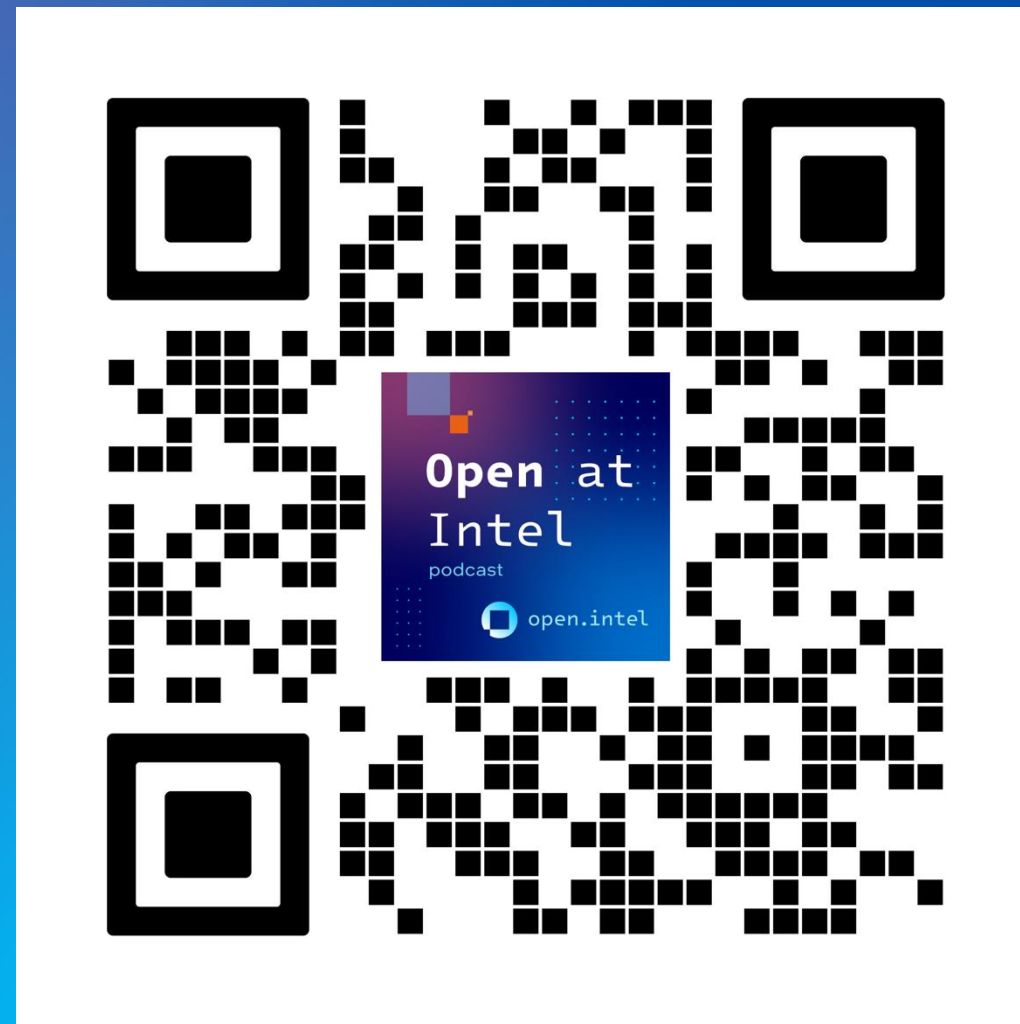


Large Language Model adversarial robustness toolkit

LLMart is a toolkit for evaluating LLM robustness through adversarial testing. Built with PyTorch and Hugging Face integrations, **LLMart** enables scalable red teaming attacks with parallelized optimization across multiple devices. **LLMart** has configurable attack patterns, support for soft prompt optimization, detailed logging, and is intended both for high-level users that want red team evaluation with off-the-shelf algorithms, as well as research power users that intend to experiment with the implementation details of input-space optimization for LLMs.

Where to find me

- Fediverse: @katherined@reality2.social
- LinkedIn: katherinedruckman
- GitHub: kdruckman



Open Platform for Enterprise AI

Thank you!



Notices and disclaimers

Intel is committed to respecting human rights and avoiding complicity in human rights abuses. See Intel's [Global Human Rights Principles](#). Intel® products and software are intended only to be used in applications that do not cause or contribute to a violation of an internationally recognized human right.

Intel® technologies may require enabled hardware, software, or service activation. No product or component can be absolutely secure. Your costs and results may vary.

© Intel Corporation. Intel, the Intel logo, and other Intel marks are trademarks of Intel Corporation or its subsidiaries. Other names and brands may be claimed as the property of others.